Projet Epita : Honeypot et automatisation de pentest

Contraintes Considérez les instructions suivantes comme les exigences formelles d'un client. Il est donc impératif de respecter l'intégralité de ce cahier des charges. De plus, vous devez aborder la soutenance orale comme la présentation de votre produit final à ce client.

Présentation Dans le cadre de ce projet, vous réaliserez, en trinôme ou en quatuor, un système intégrant un honeypot et un script de pentest automatisé, suivi du développement d'un NIDS (Network Intrusion Detection System) en Python. L'objectif est de sélectionner un honeypot, de l'éprouver à l'aide d'un script Python automatisant des tests d'intrusion, puis de collecter et d'analyser les résultats obtenus. Par la suite, vous concevrez un NIDS basique capable de capturer le trafic réseau en temps réel, d'analyser les paquets pour repérer des anomalies ou des signatures d'attaques spécifiques (telles que des scans de ports ou des attaques par déni de service), et d'alerter l'utilisateur lors de la détection d'une menace.

Le honeypot, tout comme le NIDS, devra être déployé dans un conteneur Docker. Le script d'attaque pourra, au choix, être exécuté depuis un autre conteneur Docker ou directement depuis la machine hôte.

Questions à vous poser tout au long du projet :

- Quelle est l'utilité réelle d'un honeypot et d'un NIDS ?
- À quel emplacement stratégique de l'entreprise allez-vous déployer ces deux éléments ?
- Quelle architecture allez-vous concevoir pour reproduire au mieux les conditions réelles et tester efficacement votre NIDS ?

- Comment allez-vous valider le bon fonctionnement de votre NIDS, afin de garantir qu'en condition normale il ne génère pas de fausses alertes, mais détecte uniquement les attaques ciblées ?

Étapes de réalisation :

- **Installation du honeypot :** Suivez la documentation d'installation du honeypot choisi et assurez-vous de son bon fonctionnement.

- **Test du honeypot :** Une fois le système en place, créez un script Python permettant d'automatiser un pentest sur ce honeypot (en simulant des attaques ou en automatisant un outil de test de vulnérabilités). Testez ce script sur votre cible, puis collectez et enregistrez les données générées.

- **Récupération et analyse des données :** Étudiez les informations recueillies pour identifier les tentatives d'intrusion et les techniques employées par les attaquants. Utilisez des outils d'analyse pertinents pour en extraire les données clés.

- **Développement du NIDS :** (Voir les étapes suggérées plus bas). Le rapport de détection final devra vous être envoyé par courriel, de manière chiffrée.

- **Préparation de la présentation :** Concevez une présentation de 15 minutes exposant votre démarche, les étapes réalisées, les résultats obtenus et vos conclusions. Intégrez-y des graphiques, des tableaux et des images pour rendre votre exposé clair et captivant. Assurez-vous que chaque membre de l'équipe participe activement à toutes les phases du projet.

Structure suggérée pour la présentation :

- Introduction : présentation du projet et de ses objectifs.

- Présentation du logiciel libre utilisé comme honeypot.

- Explication de l'installation du logiciel.

- Explication et démonstration de votre script Python de pentest automatisé.

- Méthodologie de récupération des données.

- Analyse des données.

- Résultats obtenus.

- Explication et démonstration de votre NIDS.

- Conclusions et perspectives.

- Session de questions.

Étapes suggérées pour le développement du NIDS

1. **Recherche et planification :** Comprendre le fonctionnement des NIDS et les attaques réseau courantes, puis définir les objectifs spécifiques de l'outil (types d'attaques ciblées, méthodes de détection, etc.).

2. **Apprentissage de Scapy :** Se familiariser avec la bibliothèque Scapy pour la capture et l'analyse des paquets réseau.

3. **Conception de l'outil :** Définir l'architecture globale incluant la capture des paquets, l'analyse, la détection des anomalies/signatures et le système d'alerte.

4. **Développement :**

    - *Capture des paquets :* Utiliser Scapy pour capturer le trafic en temps réel.

    - *Analyse des paquets :* Écrire des fonctions pour identifier les caractéristiques malveillantes (ex. : un nombre anormal de requêtes vers un même port sur un temps court).

    - *Détection d'attaques :* Implémenter des méthodes pour repérer des attaques spécifiques basées sur l'analyse précédente.

    - *Alertes :* Développer un système notifiant l'utilisateur lors d'activités suspectes.

5. **Tests et ajustements :** Éprouver l'outil dans un environnement contrôlé pour vérifier sa capacité de détection, puis ajuster les algorithmes et les seuils d'alerte selon les résultats obtenus.

Planning Intégré du Projet

Voici le calendrier des étapes à suivre pour mener à bien le projet :

- **Séance 1 : Lancement et Organisation** Présentation du sujet, constitution des groupes (trinômes ou quatuors), réflexion initiale et recherche documentaire sur les NIDS, les honeypots et Scapy.

- **Séance 2 : Bilan Intermédiaire** Fourniture d'un document PDF détaillant le nom des membres du groupe, le honeypot sélectionné, les attaques prévues pour le script, le planning prévisionnel de travail et l'état d'avancement du projet.

- **Séances 3 et 4 : Création et Finalisation du Projet** Finalisation technique du travail (installation de Docker, élaboration du script d'attaque, développement du NIDS), rédaction du rapport et préparation de la soutenance.

- **Séance 5 : Soutenance Orale** Présentation par groupe de 15 minutes, suivie d'une session de questions. L'oral doit exposer clairement les étapes suivies, les résultats obtenus et les conclusions tirées.

Annexes et concepts techniques

Qu'est-ce qu'un honeypot ? Un honeypot logiciel est un système de sécurité conçu pour attirer les cybercriminels en simulant des failles et des vulnérabilités dans un système ou une application. Son but est de piéger les attaquants afin de recueillir de précieuses informations sur leurs méthodes et leurs objectifs. L'administrateur configure une machine ou un réseau cible factice ; lorsqu'un attaquant tente de s'y introduire, le honeypot enregistre toutes ses actions (tentatives de connexion, exploitation de failles, reconnaissance, etc.). Ces données permettent ensuite d'améliorer la sécurité globale et d'identifier les menaces. Bien qu'ils ne constituent pas une solution de sécurité autonome, les honeypots sont extrêmement utiles lorsqu'ils sont couplés à des pare-feu, des NIDS ou des scanners de vulnérabilités.

Logiciel de surveillance réseau Il s'agit d'un programme conçu pour capturer et analyser le trafic sur un réseau informatique. Il permet de surveiller les performances, de détecter des pannes, d'identifier des failles de sécurité et d'analyser le comportement des utilisateurs. Généralement, son fonctionnement se divise en trois phases : la capture des données (paquets, adresses IP, ports, protocoles), l'analyse approfondie de ces données via des algorithmes spécifiques pour détecter des anomalies, et la génération de rapports détaillés. Certains outils offrent également des fonctionnalités avancées telles que la cartographie réseau ou la détection d'intrusions. Le choix du logiciel dépendra de vos besoins spécifiques.

Script Python de pentest automatisé Ce script devra exécuter diverses attaques sur le honeypot (déni de service, attaque des services, scans, force brute, injections, etc.). Il est impératif qu'il soit rigoureusement commenté et documenté. Le code devra être modularisé au maximum, par exemple en dédiant une fonction spécifique à chaque type d'attaque. De plus, une gestion complète des erreurs (exceptions) devra être prévue pour éviter que le script ne s'interrompe prématurément. L'utilisation de la programmation orientée objet (classes) et de bibliothèques externes est totalement libre.

Détection d'attaques Dans le cadre d'un NIDS en Python, la détection peut être abordée de différentes manières selon le niveau de sophistication souhaité :

1. **Détection de signatures :** Cette méthode recherche des motifs spécifiques dans les paquets réseau correspondant à des menaces connues (chaînes de caractères dans les charges utiles, drapeaux TCP inhabituels, séquences d'attaques répertoriées). Par exemple, la détection d'un scan SYN s'effectue en repérant le drapeau "S" dans les trames TCP.

2. **Détection d'anomalies :** Elle s'appuie sur l'identification d'écarts par rapport à un trafic jugé normal (statistiques, machine learning, ou règles définies manuellement). Par exemple, elle peut consister à lever une alerte si une adresse IP source envoie un volume de paquets dépassant un seuil de tolérance défini.

Conclusion La mise en œuvre d'un NIDS peut aller de simples règles statiques à des algorithmes complexes d'apprentissage automatique. Il est recommandé de débuter par des méthodes simples pour établir une base solide, avant d'explorer des techniques plus avancées visant à accroître la précision et la robustesse du système.